

5.1 Personal data

Personal data is any data that relates to an individual. This includes data such as:

- name
- date of birth
- address
- telephone number
- email address
- bank details
- medical records
- salary
- political opinions
- membership of online communities or services.

Why personal data should be kept confidential

Through sharing personal data with another person or organisations, especially online, individuals can be exposed to a range of dangers, including identity theft, fraud, bullying and blackmail. Issues relating to identity theft and fraud are often the result of individuals having their personal information shared without their permission, which is then used to withdraw money from a person's bank account, take out loans, or gain access to online accounts. Blackmail and bullying can take place when an individual has personal information they wish to keep private, such as medical conditions or political views. Alongside financial losses and a possible loss of reputation, sorting out such issues can be challenging and extremely worrying for individuals. It is therefore important to consider how information is shared online, as well as considering how data stored and transferred can be kept secure.

How personal data can be kept confidential

When sharing data online, particularly when using social media, personal data could be viewed by other people and organisations (see Figure 5.1). It is therefore important to consider what needs to be shared and, when personal data is shared, how it can be kept confidential. Steps that help to keep personal data confidential include:

- Remove **geotags** from photos/videos, which means the location details for where the content was created cannot be seen, as this could reveal an individual's home address, place of work or school. Other location services can also be disabled, including checking in at places visited.
- Check information shared on social media profiles carefully, particularly if part of a profile is public, as this can often still be used to view some personal data, such as

photos or information related to hobbies/interests.

- Ensure the personal data shared with friends or contacts on social media platforms is appropriate. For example, a social networking platform only accessed by close friends and family might be used to share different personal data from a business networking platform.

Block and report users unexpectedly asking for personal data online, such as asking for your phone number within a direct message on a social media platform.

Use a non-recognisable username rather than your real name where appropriate, for example when online gaming.

107



Figure 5.1: Personal data shared using social media needs to be carefully considered.

Anonymising information involves changing data so the individual it relates to cannot be identified, such as by replacing their full name with a unique numerical code. Anonymised information is used by many organisations to keep personal data confidential, such as when analysing how people use social media or collecting information that may be sensitive. However, it is still important to examine what data is being collected and how it is used, as the data collected could still lead to an individual being identified. For example, a person sharing their date of birth and the street they live on may be easily identifiable if someone lives in a place containing a small number of properties, which might affect their privacy if other personal data has been shared.

Problems with keeping personal data confidential often arise due to **aggregating information**. Aggregate data combines specific data related to an individual, which may lead to personal data being revealed. This could be from information explicitly shared online, or from devices, such as those connected to the IoT (Internet of Things). For example, an individual's purchases on an online shopping site could be compared with data from a smart watch, which might provide information about an individual's health or medical conditions (see Figure 5.2). This data could then be used to target advertising at the individual, or the data sold to other organisations.



Figure 5.2: A smart watch may contain information about an individual's health and fitness.

Organisations have a **duty of confidence** when personal data is shared, which means it cannot be disclosed to others without an individual's consent. However, when registering for a service, the user may be presented with several options requesting that data be shared beyond the organisation. These options need to be carefully considered to ensure personal data is shared as expected by the individual and not made available to others without the individual's consent. This is particularly important when considering how data may be aggregated.

How personal data can be kept secure

We may take a number of measures to keep ourselves safe in daily life, such as locking doors, not talking to strangers and checking carefully before crossing the road. However, when people go online, they may not be aware of the safety measures they should take or how to behave in a safe manner.

There are several guidelines that you can follow to keep your personal data secure and prevent its misuse. For example, when accessing digital devices and online services:

- Set strong passwords on any account that holds personal data, which means they cannot be easily guessed by individuals, or by automated password cracking tools. Stronger passwords include characters, numbers and symbols and are not a recognisable word, such as those found in the dictionary.
- Ensure passwords used for each service are unique. This ensures that if a password from one account is shared or compromised (an unauthorised person accesses your password), it cannot be used to access another account. Password managers can be used to help generate unique, hard to guess, passwords for all accounts used by an individual.
- Make use of **biometric** devices where available. Biometric devices use a person's unique biological data, such as a thumbprint or the iris in the eye, to quickly access

108

106

systems and authorise transactions (see Figure 5.3). Biometric data can be used in place of other authentication methods, such as passwords.



Figure 5.3: A biometric device recognises the individual's thumbprint.

Use **two-factor authentication**, often referred to as 2FA, which uses an additional means of accessing a service before allowing a user to login. Two-factor authentication often involves combining a username and password with another authentication method on a smart phone. For example, the user might need to enter a code sent to them as a text message or viewed on an app, answer an automated phone call from the service, or use an app to verify they have the phone in their possession. A security key can also be used as a form of two-factor authentication and must be inserted into a laptop / desktop computer, or held nearby for a tablet / smart phone, to access the device.

UNPLUGGED ACTIVITY 5.01

Alex is opening an online bank account. They have heard about strong passwords but are not sure what strong passwords are. Alex was born in 2006. They have a pet cat Beth and their favourite colour is purple. Advise Alex on what is a strong password from the following list:

Alex2006

AlexandBeth

BethCat?

ALeX06!

U75jSweet0

Beththecat2006

purpledaisies17

DID YOU KNOW?

Stolen personal data could be used to trick a mobile phone operator into sending a new SIM card for a user's phone to an unauthorised user, which is then inserted into a criminal's phone and used to gain access to online services using two-factor authentication.

It is also important to ensure digital devices, such as laptops, tablets or phones, are protected:

- Use **encryption** where available, which converts data stored on the device into a secret code. For example, encrypted text might be stored as a random combination of letters, numbers and other characters, so that it cannot be read if the device is stolen. Data cannot be accessed without the use of a private key, which is only available to certain users, such as the owner of the laptop when they log onto the machine. (You can find out more about encryption in [Chapter 1](#).)
- Install **anti-virus software**. Anti-virus software scans the computer to identify and remove viruses and **malware**, which can steal personal data. Anti-virus software, also known as virus checkers or anti-malware software, can also actively monitor a digital device while it is being used. This will help ensure viruses and malware do not infect the machine.
- Keep the operating system and application software up to date by installing updates regularly. Updates often resolve security issues, which can be used to steal personal data.

109

Finally, when using the internet:

- Ensure web-based content and apps used are trustworthy. Websites should be checked to ensure they use SSL (secure sockets layer), which is an encryption-based internet security protocol and often indicated by displaying a padlock symbol in a browser's address bar. (You can find out more about SSL in [Chapter 1](#).) URLs (web addresses) and a page's content should be checked to ensure they are correct and not mimicking another site.
- Check messages, such as emails or direct messages, carefully to ensure they are from a genuine source. Avoid opening links to webpages and attached files unless you know they come from a trustworthy source.

Network security measures

Public Wi-Fi networks, such as those found in coffee shops and gyms, often have limited security in place. This means care must be taken when using a device, as personal data could be intercepted or the device accessed by other people using the network.

Instead, use a **virtual private network (VPN)** to encrypt your data. A VPN ensures your data cannot be viewed by others connected to a network. It is safer to use a VPN when using online services that require you to enter personal data, such as passwords or bank details.

DISCUSSION POINT

How many of the guidelines within this chapter do you currently follow to keep your personal data confidential?

UNPLUGGED ACTIVITY 5.02

Create a plan to implement any of the guidelines that you do not currently follow to

keep your data confidential.

How personal data can be gathered by unauthorised persons

There are several ways that an unauthorised person can try to collect personal data. They include:

- phishing
- smishing
- vishing
- pharming.

Phishing

Phishing involves a person sending a realistic looking email to a user to steal their personal data. The email contains a hyperlink to a website that also looks real, such as an internet banking login page. The user is encouraged to click on the link and to input personal data into a form on the website, such as being prompted to login using their username and password. Instead, the email could simply ask the user to reply to the email with their personal data. The user is tricked into giving their personal data as they believe it is from a genuine source, although both the email and the linked website are from a fake, unauthorised source.

The personal data input is then collected by an unauthorised person. This person can use the data for criminal acts, such as to commit fraud or steal the user's identity.

110

Phishing emails often pressure or intimidate the user to act quickly, such as by threatening the user that they must click the link and correct a situation immediately, or there will be a further issue.

DID YOU KNOW?

Phishing is a respelling of the word 'fishing'. But instead of looking for fish, a person who is 'phishing' is fishing for data (see Figure 5.4).



Figure 5.4: Individuals fish for fish. They may also ‘phish’ for data!

How to recognise a phishing email

It's essential that you can recognise phishing emails to help keep your data secure and prevent it from being misused. Here are some measures you can take to protect data:

- Check the sender's name and subject line before opening the email. If the name appears fake or the subject line looks suspicious, it could be a phishing email. It may be safer to delete the email without opening it.
- Does the sender's email address look fake? Trustworthy businesses will use their own domain name.
- Check the opening line of the email. Does it address you in an impersonal way, for example 'Valued customer' or 'Dear Client'? An email from a trustworthy business will usually address you by name.
- Is the message well written? If it contains spelling mistakes and poor grammar, it may be a phishing email. It may be safer to delete the email.
- What is the content of the message? Does it ask you for personal data? Does it use aggressive language to get you to reveal your personal data such as 'Your account will be suspended if you do not act now!' Trustworthy businesses would not ask for your confidential data in this way.
- Does the message ask you to click a hyperlink? Hovering over a link allows a web address to be checked to ensure it is genuine. Trustworthy businesses use their domain name, so don't click on the link unless you are confident it is safe to do so.
- Check the signature on the email. The person named at the end of the message should include their contact information. If there is no name and no contact information, then the email is likely to be fake.
- If you think an email is phishing for data, then delete it. It may also be possible to report the phishing email to the organisation involved, which could enable the organisation to monitor communications with their customers.

DID YOU KNOW?

Many organisations regularly send fake phishing emails to their employees to test whether employees spot them and know what action to take. Employees are encouraged to report phishing emails, both real and fake. It is part of organisations' IT awareness training.

111

UNPLUGGED ACTIVITY 5.03

- 1 a** Ask a friend or a member of your family if they have ever received an email that they believed was a phishing email. Ask them how they identified it was phishing and what advice they could give to someone on how to spot phishing emails.
- b** Read the guidelines on how to recognise phishing emails above and share any guidance that may be useful with the friend/family member.

ACTIVITY 5.04

Many well-known businesses have been the target of phishing attacks. Do some research to find out about one example, and write a short report to share with your class. You could answer questions such as: How many people were affected? What did the phishing email ask people to do?

Smishing

Smishing (SMS phishing) is similar to phishing. Smishing uses mobile phone text messages to trick the mobile phone user into providing personal data, such as bank details and passwords or credit card numbers (see Figure 5.5).

The user's mobile phone receives a text message from what appears to be a genuine business, such as their bank or an online retailer. The text message may contain a link to a website, or it may ask the mobile user to call or text a telephone number to resolve an urgent issue. Mobile users will then be asked to reveal personal data, such as their login details.

Mobile phone users should be suspicious of unexpected text messages that appear to be from real companies. Banks do not contact customers asking for information in this way. The phone user may check if the website link is genuine by typing the address into their web browser rather than clicking on the link in the message. The safest way to deal with a smishing message is not to respond, block the caller's number to reduce the risk of receiving another smishing message and then delete the message.



Figure 5.5: Smishing uses text messages to obtain data illegally.

Vishing

Vishing (or voice phishing) is another type of phishing aimed at obtaining a user's personal details. The user receives a telephone call that could either be from an automated system, or it could be a real person (see Figure 5.6).

An automated voice usually speaks to the user and advises them of a problem, for example suspicious activity on their bank account. The user may then be asked to call another number, or to simply press a number on their phone and be directed to another automated system. This system will ask them to provide their bank account details to help resolve the problem. The bank account details have then been obtained by the unauthorised user and can be used to commit a crime against the user, such as transferring money from their bank account.

Sometimes, a real person may try to convince the user that there has been an issue with an account they have, then ask them to provide the login details or PIN (personal identification number) for the account to verify their identity.

To avoid becoming a victim of vishing, users should remember that no organisation will ever call and ask an individual to provide login details or PIN details over the telephone. They may ask you to provide other personal information, and if in doubt, it is advisable to end the call, and then using another phone, if possible, call the organisation back on their phone number that you may already know or can obtain.



Figure 5.6: Vishing tries to obtain data through a phone call.

Pharming

Pharming is when an unauthorised person installs malicious code on an individual's device or network hardware, such as a server. The aim of a pharming attack is to steal a user's personal data.

The malicious code is designed to redirect a user to a fake website when they type in the address of a real one. The fake website is designed to look like the real one, so they are unaware that their request has been redirected. The user will then enter their personal details into the fake website, believing it is genuine and the unauthorised person will now have their personal data.

A common technique used in pharming is domain name server (DNS) cache poisoning. This technique exploits vulnerabilities in the DNS system and diverts the internet traffic intended for a genuine server towards a fake one instead.

To carry out pharming, the unauthorised person needs to find a way to install the malicious code on the computer. They often hide the malicious code in an email attachment or link. When the user opens the email attachment or clicks the link, the malicious code is downloaded.

A real-life example of pharming

In 2007, 50 different companies all over the world were subject to a pharming attack. Over a three-day period, hackers managed to infect over 1000 personal computers a day with a malicious pharming code.

When users who had been infected visited the websites of the different companies, they were redirected to a real-looking version of the sites that were designed to steal their personal data.

The original email containing the malicious code was set up to look like a shocking news story. Users were encouraged to click a link in the email to find out more information. The code was downloaded when the user clicked the link. It is not known how much money unauthorised persons were able to steal because of this fraud.

How to prevent pharming

All of the measures to help recognise phishing, smishing and vishing attacks can be used to spot pharming. There are other things that can be done to prevent pharming attacks. These include:

- Have a firewall installed and operational. A firewall monitors incoming and outgoing traffic from your computer. It checks this traffic against set criteria and will flag and stop any traffic that does not meet the criteria. A firewall could detect and block suspicious traffic, such as a malicious code trying to enter your system. Firewalls can be implemented as software installed onto individual machines and are often part of a device's operating system, or can be a dedicated hardware device which monitors traffic for the whole network.
- Have an anti-virus program installed that is designed to detect malicious pharming code, which includes the ability to check for any malicious code. It is advisable to set up an automatic scan once a day at a time when the computer will normally be switched on.
- Be aware when using public Wi-Fi connections. A hacker could look to directly access your computer and install the malicious code if you are connected to a public Wi-Fi connection. As mentioned earlier, it is often advisable to use a VPN when using public Wi-Fi.

Smishing can also be used as a form of pharming. A mobile phone user is sent a link which downloads malware onto their mobile device when clicked. To protect against this, security software should be installed on mobile phones and the device scanned regularly to detect any presence of malware.

Questions

- 1 Investigate the use of a VPN. Find out what benefits it may have, along with any drawbacks.

113

Advantages and disadvantages of methods of preventing misuse of personal data

Table 5.1 shows a number of advantages and disadvantages to the various methods available to prevent the misuse of personal data. While each method helps keep personal data secure, its use should be carefully considered to ensure the benefits outweigh the risks. For example, a method that is time consuming to use and has a negative impact on the user is unlikely to be widely used.

Method	Advantages	Disadvantages
Strong, unique password	Can be entered quickly by the user. Requires no additional items to be used, such as a smart phone or biometric data.	Multiple passwords can be difficult to remember. Depending on the complexity of the password and the security measures in place, the password could still be compromised.

Biometrics	Always with you, so no need to remember a password or to have access to another device. Can enable almost instant log on.	Initial setup can be time consuming. Biometric data cannot be altered, unlike a password, which could be an issue if compromised.
Two-factor authentication	More secure than passwords or biometrics, as access to an additional device is required. Range of options available to authenticate, including voice calls, text messages, apps and physical security keys.	Can slow down the login process. Can be difficult to change or reset login information, particularly if a device is lost or stolen.
Encryption of data stored on a digital device	If a digital device or the storage media is stolen, the user's data cannot be accessed. Once encryption is enabled, no further action is required by the user.	Initial setup can be time consuming. If the user forgets their password/encryption key, the data cannot be accessed if the storage device needs to be moved to another computer.
Use of anti-virus software	Constantly checks for a range of viruses related to data security. Automatically kept up to date.	Can slow down using a device, such as when accessing files. May require a subscription for updates or more comprehensive protection.
Firewall	Blocks access to specific ports / services on a computer (software) or a network (hardware). Can monitor and report on unusual activity.	Can prevent all network traffic if it malfunctions or is incorrectly configured. Unable to block all unauthorised access.
Encryption of data when using a network, including Wi-Fi	Data cannot be intercepted while being transferred. Once setup by the user, functions without further intervention.	Initial setup can be costly and require technical knowledge. Can slow down network communication.

Table 5.1: Advantages and disadvantages of different methods of preventing misuse of data.